

Seguridad en Redes de Computo - Notas Semestre VI

Abraham Nuñez

June 16, 2026

Contents

1	Introducción	2
2	Información	2
2.1	Evaluación:	2
2.2	Herramientas:	2
3	Introducción a la seguridad en redes de computo	2
3.1	Seguridad de la información	3
3.1.1	Gestionar el riesgo	3
3.1.2	Regulaciones legales y estructuras de cumplimiento	4
3.1.3	Estrategias de seguridad de la información	5
3.1.4	Vector de ataque	5
3.2	ACL	5
3.2.1	Funcionamiento	6
3.2.2	Mascara Wildcard	6
3.3	VPN's	7
3.4	Tuneles	7
3.5	Tunel PPTP	7
3.6	TLS HANDSHAKE	7
3.7	RSA	7
3.8	Diffie-Hellman	7
3.9	Open VPN	8
3.10	Configuracion de AutoVPN	8
3.11	Detección de intrusiones	9
3.11.1	Funciones clave de los IDPS	9
3.11.2	Tecnicas de respuesta de los IPS	10

3.11.3	Precisión en la detección	10
3.11.4	Metodologías de detección comunes	10
3.11.5	Tipos de tecnologías IDPS	11
3.11.6	Componentes típicos de IDPs	12
3.11.7	Capacidades de detección	12
3.11.8	IDPs basado en red	12
3.11.9	Capacidades de prevención	13
3.11.10	Soluciones de NIDPS Open Source	13

1 Introducción

- Profesor: Martha Elizabet Dominguez Barcenás
- Materia: Seguridad en Redes de Computo
- Carrera: Ciberseguridad e Infraestructura de Computo

2 Información

2.1 Evaluación:

- Exámenes: 45%
- Actividades: 30%
- Proyecto final: 25%

2.2 Herramientas:

- GNS3
- Packet Tracer
- Material de Cisco

3 Introducción a la seguridad en redes de computo

- Los sistemas de información sostienen la forma en la que la mayoría de las organizaciones hacen negocios.
- Información: Incluye datos, conocimiento, propiedad intelectual, etc. Que son importantes para una organización.

- La triada CIA:
 - Confidencialidad
 - Accesibilidad
 - Disponibilidad
 - No repudio: Es la capacidad de demostrar el origen de la creación o modificación de cierta información.

3.1 Seguridad de la información

- Riesgo: Potencial de pérdida, mediante el impacto y la probabilidad de una amenaza aproveche de una vulnerabilidad en uno o mas activos de un sistema de información.
 - Activo: Algo de valor para la organización. Como sistemas de información, información. Pueden ser activos digitales, físicos e incluso reputacionales.
- Amenaza: Peligro potencial para los activos, los datos o la red de una organización. Incluye un actor de amenaza o perpetrador de hechos que representan la amenaza.
 - Hackers maliciosos.
 - Empleado deshonestos.
 - Empleado que abre un archivo malicioso.
 - Los actores de amenaza se pueden clasificar en: agentes maliciosos internos, agentes maliciosos externos, internos e internos accidentales.
- Vulnerabilidad: Es la debilidad de un activo (en un sistema o en su diseño) que puede ser explotada por una amenaza.
 - Activos de hardware
 - Activos de software

3.1.1 Gestionar el riesgo

- Proceso de minimizar el potencial de pérdida.
- Implica identificar, evaluar, priorizar riesgos y aplicar medidas de control.

- Proporcionar transparencia y contabilidad de las operaciones diarias en una organización, alineando los riesgos con los objetivos estratégicos.
- Ayuda a la organización a prepararse para eventos adversos que podrían impactarle negativamente.

1. Tratamiento del riesgo

(a) Forma de control

- Evitar el riesgo.
- Reducir el riesgo.
- Transferir el riesgo.
- Aceptar el riesgo.

(b) Controles de mitigación

- Metodos por los cuales se intenta proteger cada activo de amenazas (contra-medida que reduce la probabilidad o la gravedad de una amenaza o riesgo).
 - Riesgo residual: Despues de aplicar el control de mitigación, se vuelve un riesgo aceptable.

3.1.2 Regulaciones legales y estructuras de cumplimientos

- Los requisitos de la organización podrian proceder de autoridades gubernamentales o de organismos de certificación.
- Tambien hay estandares como los de la Organización Internacional para la Estandarización (ISO).
 - ISO 27001
 - ISO 27018
- Las organizaciones que cumplen con los requisitos establecidos en la norma estan listas para ser auditadas por terceros y obtener certificaciones o acreditaciones al respecto.
- Importancia de una certificación:
 - Altamente valoradas por los clientes y empresas asociadas.
 - Evidencia de que se ha alcanzado el nivel minimo de seguridad en la organización.
 - Las regulaciones estan en constante evolución, por lo que la organización debe estar al pendiente de ello.

3.1.3 Estrategias de seguridad de la información

- Las organizaciones requieren de programas de seguridad de la información, documentados y actualizados regularmente (la periodicidad de la norma a seguir).
- Debe incluir:
 - Creación de políticas, procedimientos y manuales de seguridad de la información.
 - Establecimiento y mantenimiento de un programa de concientización.
 - Gestión de riesgos por parte de terceros (servicios en la nube: SLA).
 - Presentación de informes y mejora continua.
 - * Captar la atención de personas interesadas.
 - * Resaltar la relación costo-beneficio de la estrategia de seguridad de la información.

3.1.4 Vector de ataque

- Ruta por la que un actor de amenaza puede obtener acceso a un recurso en la red.
- Se originan dentro y fuera de la red corporativa.
 - Ataque de DoS
 - Robo o copia de datos confidenciales
 - Desconexión de la red.

1. Ataques de red habituales

- Ataques de reconocimiento
- Ataques de acceso
- Ingeniería social
-

3.2 ACL

- Proporcionar control de flujo de tráfico. Limitar tráfico a ciertos enlaces, restringir entrega de actualizaciones.

3.2.1 Funcionamiento

- Se pueden aplicar para trafico entrante y saliente
 - Paquetes que ingresan por interfaz de entrada (antes de su busqueda en la table de routing)
 - Paquetes que salen por las interfaces de salida del router (despues de que se enrutan)
- Router compara IPv4 de origen con cada ACE en orden secuencial.
- Si hay coincidencia se ejecuta la ACE (las ACE restantes)

3.2.2 Mascara Wildcard

- Para coincidencia con un host
 - Host: 192.168.1.1
 - Wildcard: 0.0.0.0
- Para coincidencia con una subred IPv4
 - 192.168.1.0/24
 - $255.255.255.255 - 255.255.255.0 = 0.0.0.255$
 - Mascara Wildcard: 0.0.0.255
- Para coincidencia de distintas subredes
 - 192.168.10.0 y 192.168.11.0
 - Calculas mascara summarizada: $255.255.254.0$ 10 = 00001010 11 = 00001011
 - Calculo de mascara wildcard: 0.0.1.255
- Para coincidencia con un rango de direcciones:
 - Ejemplo de rango: 192.168.16.0/24 a 192.168.31.0/24
 - Mascara de subred summarizada: $255.255.240.0$ 16 = 00010000 31 = 00011111
 - Mascara wildcard: $255.255.255.255 - 255.255.240.0 = 0.0.15.255$

1. Palabras clave

- Host: Equivale a una mascara wildcard 0.0.0.0
- Any: Equivale a una mascara wildcard 255.255.255.255

3.3 VPN's

- Las organizaciones usan redes privadas virtuales (VPN) para crear conexiones de red privada de extremo a extremo. Una VPN es virtual porque transporta la información dentro de una red privada, pero en realidad, esa información se transporta usando una red publica.

3.4 Tuneles

3.5 Tunel PPTP

3.6 TLS HANDSHAKE

- El intercambio de datos de la aplicacion mediante TLS requiere la negociación previa de un tunel de cifrado.
- Cliente servidor deben acordar:
 - La versión de TLS a utilizar
 - Elegir el conjunto de cifrado
 - Verificar los certificados
- Se realiza el handshake de TCP
- Cliente envia versión de TLS, lista de conjunto de cifrado compatibles y otras opciones de TLS que se desee utilizar (CLient Hello)
- Servidor selecciona version

3.7 RSA

- Sistema criptográfico de clave publica o asimétrica, de Rivest, Shamir y Adleman.
- Mecanismo de intercambio de claves predominante en la mayoría de las implementaciones de TLS
- Esta clave simétrica negociada se utiliza para cifrar su sesión

3.8 Diffie-Hellman

- Cliente y servidor pueden negociar el secreto compartido.
- Los peers intercambian un valor inicial publicamente.

- Los peers guardan un valor secreto.
- Cada peer mezcla el valor publico con el valor secreto, obteniendo un valor distinta cada uno.
- El valor se intercambia publicamente.
- Cada peer combina dicho valor con su valor secreto.
- El resultado es un valor final idéntica en cada peer.
- El valor final es la clave compartida.

3.9 Open VPN

- Es una VPN SSL
- Implementa la extensión de red segura de capa 2 o 3 mediante el protocolo SSL/TLS
- Admite metodos de autenticación de cliente

3.10 Configuracion de AutoVPN

- apt-get install openvpn easy-rsa
- ls /etc/openvpn
- make-cadir easy-rsa (en /etc/openvpn)
- cd easy-rsa/
- ls -la
- ./easyrsa init-pki (en /easy-rsa)
- ls -la
- vim /easyrsa/vars
- ./easyrsa build-ca (en /easy-rsa)
- poner un password (importante recordar)
- SRC CA
- ls pki/ca.crt

- `ls -la pki/`
- `ls pki/private`
- `cd easy-rsa/`
- `./easyrsa gen-req servidor-src-licic nopass`
- `./easyrsa sign-req server servidor-feiuv`
- `./easyrsa gen-req cliente1-feiuv nopass`
- `./easyrsa sign-req client cliente1-feiuv`

3.11 Detección de intrusiones

- Supervisar eventos en un sistema informático o una red y analizarlos en busca de indicios de posibles incidentes.
- Incidentes: Amenazas inminentes de infracción de las políticas de seguridad informática. Puede tener múltiples causas.
- IDS: Programa informático que automatiza el proceso de detección de intrusiones.
- IPS: Programa informático que tiene las
- Enfoque en la identificación de posibles incidentes.
- No detectan cuando un sistema ya fue comprometido
- Identificación de problemas en las políticas de seguridad.
- Documentación de amenazas para la organización.
- Disuadir a personas de infringir políticas de seguridad.

3.11.1 Funciones clave de los IDPS

- Registro de información sobre los eventos observados
- Notificación de eventos observados al administrador de seguridad.
- Generación de reportes.

3.11.2 Técnicas de respuesta de los IPS

- Detiene el ataque por si mismo.
- Modifica el entorno de seguridad.
- Modifica el contenido del ataque.

3.11.3 Precisión en la detección

- Los IDPS no son totalmente precisos.
- Falsos positivos: Actividad benigna como maliciosa.
- Falsos negativos: Actividad maliciosa como benigna.

3.11.4 Metodologías de detección comunes

1. Detección basada en firmas

- Firma: Un patron que corresponde a una amenaza conocida.
- Proceso de comparar firmas contra eventos observados para identificar posibles incidentes.
- Es ineficaz para detectar amenazas no conocidas o camufladas mediante tecnicas de evasión.

2. Detección basada en anomalias

- Proceso de comparar definiciones de lo que se considera una actividad normal con los eventos observados para identificar desviaciones significativas.
- Usa perfiles que representan un comportamiento normal de elementos como usuarios, host, conexiones de red o aplicaciones.
- Es muy efectiva detectando amenazas desconocidas previamente.
- Periodo de entrenamiento que puede durar dias o semanas.

(a) Tipos de perfiles

- Perfil estatico: No cambia el perfil, solo cuando el IDPS sea configurado para generar un nuevo perfil.
- Perfil dinamicos: Se ajusta constantemente con eventos adiciones que son observados .

- Ambientes muy diversos o dinamicos, pueden generar muchos falsos positivos.

3. Analisis de protocolos con estado

- Proceso de comparar perfiles predeterminados de funciones generalmente aceptadas, como actividades de protocolos benignas para cada estado del protocolo, con los eventos observados y con el fin de identificar desviaciones.
- Se basa en perfiles universales desarrollados por los proveedores que especifican como deben y como no deben utilizarse determinados protocolos.
- Con estado: Significa que el IDPS es capaz de comprender y rastrear el estado de los protocolos de red, transporte y aplicación (que tienen noción de estado).
- Protocolo con estado: FTP
- Permite identificar secuencias de comandos inesperadas
- Con protocolos que realizan autenticación
- Comprueba aspectos como la longitud minima y maxima de los argumentos para un comando.
- Se basan principalmente en estandares de protocolo de proveedores y organismos de normalización como la IETF
- Consumen muchos recursos, debido a la complejidad del analisis.
- No pueden detectar ataques que no violen las características de comportamiento “aceptable” de un protocolo.
- El modelo de protocolo utilizado por un IDPS podria entrar en conflicto con la forma en que se implementa el protocolo en una aplicación o sistema operativo específico.

3.11.5 Tipos de tecnologías IDPS

- Basados en red
- Inalambricos
- Basados en analisis de red (NBA)
- Basados en host2

3.11.6 Componentes típicos de IDPs

- Sensor o agente.
- Servidor de gestión
- Servidor de gestión
- Servidor de base de datos
- Consola

3.11.7 Capacidades de detección

- Umbrales
- Listas negras: Actividades maliciosas
- Listas blancas: Actividades benignas
- Configurar alertas
- Edición y visualización del código

3.11.8 IDPs basado en red

- Sensores (appliance)
- Uno o mas servidores de gestión
- Múltiples consolas
- Uno o mas servidores de BD (opcional)
- Las tarjetas están en modo promiscuo para aceptar todos los paquetes entrantes detectados.
- Pueden instalarse en uno o dos modos
 - En línea/Inline: El tráfico supervisado debe de pasar a través de él.
 - Pasivo/Passive: Supervisa una copia del tráfico real. No pasa a través del sensor.

3.11.9 Capacidades de prevención

- Finalizar sesiones TCP
- Implementar firewall en línea
- Limite de bandwidth
- Alteración de contenido malicioso
- Reconfiguración de dispositivos de red
- Ejecución de un programa o script

3.11.10 Soluciones de NIDPS Open Source

- Snort
- Suricata
- Zeek